

Introducción a la Seguridad Informática, Unidad I

Índice de Contenido

- [Introducción](#)
- [Desarrollo de Contenidos](#)
 - [Visión Estratégica de la Seguridad de los datos en la Empresa](#)
 - [Elementos de la Seguridad de la Información](#)
 - [Espionaje Industrial](#)
 - [Estándares y Certificaciones](#)
- [Autoevaluación](#)
- [Bibliografía y Webgrafía](#)
- [Glosario](#)

Introducción

Cuando hablamos de seguridad informática, muchos piensan solo en antivirus o contraseñas. Sin embargo, la realidad es mucho más amplia y profunda. La información se ha convertido en el activo más valioso de cualquier organización, y protegerla requiere entender desde la estrategia de negocio hasta los detalles técnicos del cifrado. En esta unidad comenzaremos por lo fundamental: ¿qué significa realmente proteger la información? ¿Por qué empresas aparentemente sólidas han quebrado tras un ciberataque? ¿Cómo se organiza internacionalmente la gestión de la seguridad?

A lo largo de estas páginas exploraremos la visión estratégica que la alta dirección debe tener sobre la seguridad, los principios básicos que todo profesional debe conocer (confidencialidad, integridad, disponibilidad), las amenazas silenciosas como el espionaje industrial, y los marcos de trabajo que permiten certificar que una organización maneja la seguridad de manera competente. También pondremos manos a la obra con una herramienta real de cifrado, GnuPG, porque la teoría sin práctica se olvida pronto.

Te invito a leer con calma, a cuestionarte cada ejemplo y a relacionarlo con tu propia experiencia o con noticias que hayas visto. La seguridad informática no es un conjunto de recetas mágicas; es una disciplina que se construye con conocimiento, conciencia y buenas prácticas.

Desarrollo de Contenidos

Visión Estratégica de la Seguridad de los datos en la Empresa

Para empezar, conviene entender un cambio fundamental que ha ocurrido en las últimas dos décadas. Antes, la seguridad informática se veía como un mal necesario: "compremos un firewall y un antivirus, y ya estamos protegidos". Esa visión ingenua ha dejado paso a un enfoque estratégico. La seguridad hoy es un habilitador del negocio, no un freno.

Una visión estratégica implica que la protección de los datos está alineada con los objetivos de la organización. Por ejemplo, si una empresa de comercio electrónico quiere crecer, necesita garantizar la confidencialidad de las tarjetas de crédito de sus clientes; si falla, no solo perderá ventas, sino que enfrentará multas y demandas. La estrategia de seguridad debe responder preguntas como: $\neg$ cuáles son nuestros activos críticos? $\neg$ Qué riesgos estamos dispuestos a asumir? $\neg$ Cuánto invertimos en proteger cada activo?

Elementos de una estrategia de seguridad sólida:

- **Gobierno de seguridad:** un comité directivo que revisa las políticas y asigna recursos.
- **Análisis de riesgos:** identificar, evaluar y priorizar los riesgos (no todos merecen la misma protección).
- **Plan de respuesta a incidentes:** saber qué hacer cuando (no si) ocurre una brecha.
- **Concienciación continua:** la mayoría de los incidentes involucran error humano; formar a los empleados es tan importante como la tecnología.

Conceptos actuales que toda estrategia debe integrar:

- **Modelo Zero Trust:** nunca confiar automáticamente, siempre verificar cada acceso, incluso desde la red interna. Implica microsegmentación, autenticación continua y mínimos privilegios.
- **GDPR (Reglamento General de Protección de Datos):** desde 2018, cualquier empresa que trate datos de ciudadanos europeos debe cumplir estrictos requisitos de confidencialidad, notificación de brechas en 72 horas y derecho al olvido. Ignorarlo puede costar multas de hasta 20 millones de euros o el 4% de la facturación global.
- **Seguridad en la nube:** ya no basta con proteger el perímetro; se deben gestionar identidades, configuraciones de buckets (como el caso Verizon), y usar cifrado gestionado por el cliente.
- **Inteligencia artificial en ciberseguridad:** tanto para defensa (detección de anomalías, análisis de comportamiento) como para ataque (deepfakes, phishing automatizado). Una estrategia moderna debe considerar cómo la IA amplifica riesgos y oportunidades.

Ejemplo real que ilustra la falta de visión estratégica:

El caso de **Target Corporation** en 2013. Esta cadena de tiendas estadounidense sufrió una brecha masiva donde se robaron 40 millones de números de tarjetas de crédito y 70 millones de registros de clientes. El ataque comenzó cuando un proveedor de calefacción, ventilación y aire acondicionado (HVAC) tuvo sus credenciales comprometidas. $\neg$ Por qué un proveedor de HVAC tenía acceso a la red de pago de Target? Porque no existía una segmentación adecuada ni una política de acceso mínimo necesario. La falta de visión estratégica (considerar la seguridad desde el diseño de la red y las relaciones con terceros) costó a Target más de 200 millones de dólares en arreglos y una enorme pérdida de reputación.

Ejemplo de evolución estratégica exitosa:

Microsoft ha demostrado una evolución notable. Desde la iniciativa "Secure Development Lifecycle" (SDL) hasta la integración de seguridad por defecto en Windows y Azure, la compañía ha convertido la seguridad en un pilar competitivo. Invierten miles de millones anualmente, pero el retorno es la confianza de gobiernos y grandes empresas que adoptan su nube. Además, han adoptado explícitamente el modelo Zero Trust en sus productos y recomiendan autenticación multifactor (MFA) obligatoria para todos los inquilinos de Azure.

Otro caso actual de fracaso estratégico:

En 2021, **Colonial Pipeline** pagó 4.4 millones de dólares de rescate por un ataque de ransomware. La causa raíz fue una cuenta VPN sin autenticación multifactor y una segmentación de red deficiente. La lección: la estrategia de seguridad debe priorizar el acceso remoto y asumir que las credenciales pueden ser robadas.

Conclusión práctica para la empresa:

Una visión estratégica no significa comprar la tecnología más cara, sino tomar decisiones basadas en riesgos. Por ejemplo, si una pequeña empresa maneja datos de salud, deberá invertir en cifrado y controles de acceso; si solo tiene información pública, bastará con proteger la disponibilidad. Lo importante es que la seguridad esté dirigida desde la alta dirección y se revise periódicamente, al menos una vez al año o tras cada incidente relevante.

Elementos de la Seguridad de la Información

Los tres pilares clásicos son confidencialidad, integridad y disponibilidad. A menudo se representan con el triángulo CIA (Confidentiality, Integrity, Availability). Pero no son meras palabras; cada uno tiene técnicas específicas y consecuencias cuando fallan. A estos tres se añaden con frecuencia autenticidad, no repudio y privacidad.

Confidencialidad

Es la propiedad que impide que la información sea revelada a personas, entidades o procesos no autorizados. La violación típica es que alguien no autorizado lea un dato. Por ejemplo, un hacker que intercepta un correo electrónico o un empleado curioso que accede a nóminas.

Mecanismos para garantizar confidencialidad:

- Cifrado (en reposo, en tránsito).
- Controles de acceso (autenticación y autorización).
- Segmentación de redes y firewalls.
- Políticas de clasificación de información.
- Autenticación multifactor (MFA) para accesos remotos.

Ejemplo de fallo de confidencialidad:

El caso de **Equifax** en 2017. Una vulnerabilidad en Apache Struts no fue parcheada a tiempo. Los atacantes robaron datos personales de 147 millones de estadounidenses: nombres, números de seguro social, fechas de nacimiento. La información sensible quedó expuesta por negligencia en la gestión de parches. El costo: más de 1.400 millones de dólares en multas y acuerdos.

Integridad

Asegura que la información y los métodos de procesamiento sean exactos y completos, y que no sean modificados de manera no autorizada. No basta con que nadie lea un dato; también debe importarnos que nadie lo cambie indebidamente. Un ejemplo crítico es la modificación de un registro financiero o la alteración de una receta médica.

Mecanismos para garantizar integridad:

- Sumas de verificación (hashes como SHA-256).
- Firmas digitales.
- Registros de auditoría (logs).
- Controles de versiones y bloqueo de ediciones concurrentes.

Caso real documentado:

En 2018, un atacante modificó las calificaciones de estudiantes en el sistema **Infinite Campus** usado por varias escuelas de EE.UU. Aunque no se trató de un hackeo masivo, el incidente mostró cómo cuentas mal protegidas pueden alterar la integridad de registros académicos. La escuela afectada tuvo que restaurar desde copias de seguridad y reforzar la autenticación de profesores.

Disponibilidad

Garantiza que los usuarios autorizados tengan acceso a la información y a los sistemas cuando lo requieran. La denegación de servicio (DDoS) es el ataque más común contra la disponibilidad, pero también los fallos de hardware, los cortes eléctricos o los errores humanos.

Mecanismos para garantizar disponibilidad:

- Redundancia (servidores, discos, enlaces).
- Copias de respaldo y planes de recuperación ante desastres.
- Sistemas de alimentación ininterrumpida (UPS).
- Balanceo de carga y tolerancia a fallos.

Ejemplo impactante:

En octubre de 2016, el proveedor de DNS Dyn sufrió un ataque DDoS masivo utilizando la botnet Mirai (dispositivos IoT infectados). Grandes plataformas como Twitter, Netflix, Reddit, Spotify y PayPal estuvieron inaccesibles durante horas en la costa este de EE.UU. La indisponibilidad causó pérdidas estimadas en 110 millones de dólares solo por ventas no realizadas en Amazon y otros sitios. Un ejemplo más reciente: en 2023, un DDoS contra **ChatGPT** lo dejó inaccesible de forma intermitente durante varios días, afectando a millones de usuarios.

Otros elementos complementarios

A los tres pilares se añaden con frecuencia:

- **Autenticidad:** certeza de que la identidad de un sujeto o el origen de un dato es genuino. Se logra con firmas digitales y certificados.
- **No repudio:** imposibilidad de negar una acción realizada (por ejemplo, haber enviado un mensaje). También se apoya en firmas digitales y registros de auditoría inmutables.

- **Privacidad:** derecho de las personas a controlar sus datos personales. Es un concepto legal y ético, pero se apoya en la confidencialidad e integridad. El GDPR y leyes similares han elevado la privacidad a requisito obligatorio.

Tabla resumen de los principios CIA

Principio	Definición breve	Mecanismo principal	Ejemplo de fallo
Confidencialidad	Solo autorizados pueden ver	Cifrado, control de acceso	Equifax (robo de datos)
Integridad	Los datos no se modifican sin permiso	Hashes, firmas digitales	Modificación de notas escolares
Disponibilidad	Acceso oportuno cuando se necesita	Redundancia, respaldos	Ataque DDoS a Dyn

Reflexión: Los tres principios a menudo entran en conflicto. Por ejemplo, cifrar muy fuerte puede ralentizar el acceso (afectando disponibilidad). Verificar cada cambio puede consumir recursos. Una buena estrategia de seguridad equilibra los tres según la criticidad de cada activo.

Espionaje Industrial

El espionaje industrial no es un invento de Hollywood. Es una práctica real que empresas, e incluso estados, utilizan para obtener ventajas competitivas. Consiste en la obtención ilícita de información confidencial de una empresa: secretos comerciales, estrategias de mercado, listas de clientes, patentes, fórmulas, etc.

Técnicas más comunes observadas en la práctica:

- **Ingeniería social:** manipular a empleados para que revelen contraseñas o información sensible. Por ejemplo, llamar haciéndose pasar por soporte técnico.
- **Phishing y spear phishing:** correos electrónicos engañosos que parecen legítimos. El spear phishing está dirigido a un objetivo concreto con mensajes personalizados.
- **Malware específico:** troyanos que extraen documentos y los envían a servidores externos.
- **Ataques a la cadena de suministro:** comprometer a un proveedor para llegar al objetivo final.
- **Dispositivos físicos:** keyloggers, grabación de conversaciones, revisión de papeles desechados (dumpster diving).
- **Deepfakes y suplantación de identidad avanzada:** uso de inteligencia artificial para imitar voces o videos de directivos, solicitando transferencias o datos confidenciales.

Caso emblemático de espionaje industrial:

El affaire **Alstom vs. General Electric** (2013-2015). Alstom, una empresa francesa de energía, fue acusada por el Departamento de Justicia de EE.UU. de sobornos en varios países. Durante la investigación, se descubrió que Alstom había contratado a consultores que, en realidad, recopilaban información confidencial de sus competidores. Si bien el caso central fue por corrupción, incluyó prácticas de inteligencia competitiva ilícita. Finalmente, Alstom fue condenada y su división de energía fue adquirida

por General Electric por 12.400 millones de euros. Muchos expertos señalan que el caso combinó espionaje industrial con maniobras geopolíticas.

Caso claro de robo de secretos comerciales:

Waymo vs. Uber (2017). Un ingeniero de Waymo (la división de vehículos autónomos de Google) descargó más de 14.000 archivos confidenciales que contenían diseños de sensores LiDAR y se unió a Uber. Uber negó haber usado los archivos, pero el caso se resolvió con Uber pagando a Waymo 245 millones de dólares en acciones. Este es un ejemplo típico de espionaje mediante exfiltración de datos por parte de un empleado desleal.

Otro caso muy conocido de suplantación:

En 2017, **Google y Facebook** fueron víctimas de un fraude de facturación masivo (no exactamente espionaje, pero sí ingeniería social avanzada). Un atacante lituano fingió ser la empresa asiática Quanta Computer (proveedora real de ambas). Envío facturas falsas y logró que Google y Facebook le pagaran más de 100 millones de dólares. El engaño duró dos años. Este caso muestra cómo la suplantación de identidad de un socio comercial puede causar pérdidas millonarias.

Medidas de protección contra espionaje industrial:

- Clasificación de información y control de acceso basado en roles (principio de mínimo privilegio).
- Formación continua en detección de ingeniería social y phishing (simulaciones periódicas).
- Cifrado de datos sensibles, incluso internamente, y uso de soluciones DLP (Data Loss Prevention) que monitoricen la salida de información.
- Monitorización de accesos y de la red, con alertas ante descargas masivas o accesos anómalos.
- Acuerdos de confidencialidad y cláusulas de seguridad en contratos con proveedores y empleados.
- Autenticación multifactor (MFA) para sistemas que contengan secretos comerciales.
- Programas de "insider threat" que detecten comportamientos sospechosos de empleados con privilegios.

Reflexión final:

El espionaje industrial suele ser silencioso y difícil de detectar porque no siempre implica ruido técnico. Muchas veces, la información sale por una conversación casual en un bar, un correo mal dirigido o un USB perdido. La concienciación del personal y la revisión periódica de accesos son tan importantes como los firewalls.

Estándares y Certificaciones

Cuando una organización desea demostrar que maneja la seguridad de manera profesional, recurre a estándares y certificaciones. No basta con decir "somos seguros"; hay que someterse a auditorías externas.

Principales estándares internacionales:

- **ISO/IEC 27001:** Es el estándar estrella para Sistemas de Gestión de Seguridad de la Información (SGSI). Establece requisitos para implementar, operar, monitorear, revisar, mantener y mejorar un SGSI. La versión actual es ISO 27001:2022. Una empresa certificada en ISO 27001 demuestra que tiene un enfoque sistemático basado en riesgos.
- **ISO/IEC 27002:** Es un código de prácticas que ofrece una guía de controles de seguridad (114 controles en la versión 2022). No es certificable por sí mismo, sino complementario al 27001.

- **NIST SP 800-53**: Desarrollado por el Instituto Nacional de Estándares y Tecnología de EE.UU. Es muy utilizado por agencias gubernamentales y empresas que trabajan con el gobierno. Proporciona un catálogo de controles de seguridad y privacidad. Su versión más reciente (revisión 5) incluye controles para sistemas de inteligencia artificial y actualizaciones sobre privacidad.
- **PCI DSS** (Payment Card Industry Data Security Standard): Obligatorio para cualquier entidad que procese, almacene o transmita datos de tarjetas de crédito. Consta de 12 requisitos (desde instalar firewalls hasta realizar pruebas de penetración). La versión 4.0 entró en vigor en 2024, con requisitos más estrictos sobre autenticación multifactor y gestión de parches.

Certificaciones profesionales:

- **CISSP** (Certified Information Systems Security Professional): Para arquitectos y gerentes de seguridad. Reconocida mundialmente.
- **CISM** (Certified Information Security Manager): Enfocada en la gobernanza y gestión.
- **CompTIA Security+**: Certificación de nivel inicial, ideal para empezar.
- **CEH** (Certified Ethical Hacker): Para profesionales de pruebas de penetración.

Caso de éxito con estándares:

La aerolínea **Delta Air Lines** obtuvo la certificación ISO 27001 para sus sistemas de reservas y gestión de pasajeros. Tras una auditoría rigurosa, identificaron brechas en la gestión de parches y en el control de acceso de proveedores. Corregirlas no solo les evitó posibles multas (por el cumplimiento de PCI DSS y GDPR), sino que redujo en un 40% los incidentes de seguridad en dos años.

Caso de fracaso por ignorar estándares:

En 2017, **Verizon Partner Solutions** dejó expuestos los datos de 14 millones de clientes debido a un bucket de Amazon S3 mal configurado. Un investigador de seguridad encontró la información sin ninguna protección. Verizon no había seguido las buenas prácticas del NIST o ISO 27001 sobre configuración segura de servicios en la nube (por ejemplo, controles de acceso y revisión periódica de permisos). La violación de confidencialidad afectó a clientes de su servicio de negocio. La multa fue menor, pero el daño reputacional fue enorme.

Tabla resumen de estándares y su ámbito:

Estándar	Ámbito principal	Certificable	Uso típico
ISO 27001	SGSI - gestión de seguridad	Sí (organización)	Empresas de cualquier sector
ISO 27002	Guía de controles	No	Complemento del 27001
NIST SP 800-53	Controles de seguridad y privacidad	No (pero se audita)	Gobierno y contratistas de EE.UU.
PCI DSS	Datos de tarjetas de pago	Sí (autoevaluación o auditoría)	Comercios, bancos, procesadoras

Recomendación práctica:

Para una pyme, empezar con ISO 27001 puede ser costoso. Se recomienda primero adoptar el conjunto de controles de ISO 27002 o seguir guías del NIST (como el Cybersecurity Framework) para madurar

procesos, y luego buscar certificación si clientes o regulaciones lo exigen. Las certificaciones profesionales (como Security+ o CISSP) son valiosas para el equipo de seguridad, pero no eximen a la organización de tener un SGSI formal.

Autoevaluación

Autoevaluación

Lea cada pregunta, responda mentalmente y luego consulte el glosario o los conceptos si tiene dudas. Las respuestas no se entregan; son para su propio aprendizaje.

1. **Verdadero o falso:** El modelo Zero Trust implica confiar automáticamente en todos los dispositivos que se encuentren dentro de la red interna de la empresa.

Respuesta esperada: Falso. Zero Trust se basa en "Nunca confiar, siempre verificar"; ni siquiera los dispositivos internos son confiables por defecto.

2. **¿Cuál de los siguientes NO es un mecanismo de confidencialidad?**

- a) Cifrado
- b) Autenticación multifactor (MFA)
- c) Firma digital
- d) Segmentación de red

Respuesta: c) Firma digital. La firma digital garantiza integridad y no repudio, no confidencialidad. El MFA sí ayuda a la confidencialidad porque evita accesos no autorizados.

3. **Mencione al menos dos técnicas de espionaje industrial que utilicen inteligencia artificial o ingeniería social avanzada.**

Respuesta posible: Deepfakes (suplantación de voz o video de directivos), spear phishing con mensajes generados por IA, ataques a la cadena de suministro.

4. **Según el GDPR (Reglamento General de Protección de Datos), ¿en cuánto tiempo máximo debe una empresa notificar una brecha de datos a la autoridad de control?**

Respuesta: 72 horas desde que tuvo conocimiento de la brecha.

5. **Explique con sus palabras la diferencia entre cifrar un archivo y firmar digitalmente un archivo.**

Respuesta esperada: Cifrar protege la confidencialidad (solo el destinatario puede leer). Firmar garantiza integridad y autenticidad (cualquiera puede verificar que el archivo no fue alterado y que proviene de quien dice ser).

6. **Caso práctico:** Una empresa tiene servidores en una sala sin UPS ni generador. Un corte eléctrico deja los sistemas inaccesibles durante 6 horas. ¿Qué principio de seguridad se ha vulnerado principalmente?

Respuesta: Disponibilidad, porque los usuarios autorizados no pudieron acceder a los sistemas cuando lo necesitaban.

7. **¿Cuál fue la principal lección del ataque a Colonial Pipeline (2021) sobre autenticación?**

Respuesta: La cuenta VPN comprometida no usaba autenticación multifactor (MFA). El MFA habría bloqueado el acceso incluso con contraseña robada.

8. Relacione la certificación profesional con su enfoque principal:

- CISSP (Gestión y arquitectura de seguridad / Hacking ético)
- CEH (Hacking ético)
- CISM (Gobierno y gestión)

Respuesta: CISSP (gestión y arquitectura de seguridad); CEH (hacking ético); CISM (gobierno y gestión).

9. ¿Qué comando de GnuPG generaría una firma en texto claro (legible)?

Respuesta: `gpg --clearsign documento.txt`

10. Reflexión final: A pesar de casos como Equifax, Colonial Pipeline y el robo de secretos de Waymo, muchas pequeñas y medianas empresas aún no implementan estrategias básicas de seguridad.

¿Qué factores cree que lo explican?

Respuesta abierta. Se espera que el estudiante mencione: costo aparente, falta de conciencia de la dirección, creencia de que "La mía no me va a pasar", desconocimiento técnico, o ausencia de requisitos legales en su sector.

Si obtuvo menos de 7 respuestas correctas, revise nuevamente las secciones de Elementos de seguridad, Estándares, Espionaje industrial y los casos de Colonial Pipeline y GDPR.

Bibliografía y Webgrafía

- Ramío, J. (2010). *Seguridad Informática y Criptografía*. CriptoRed.
- Stallings, W. (2006). *Cryptography and Network Security* (4^a ed.). Prentice Hall.
- Schneier, B. (1996). *Applied Cryptography* (2^a ed.). John Wiley & Sons.
- ISO/IEC 27001:2022. *Information security, cybersecurity and privacy protection – Information security management systems*. ISO.
- The Open Web Application Security Project (OWASP). Disponible en: <https://owasp.org/>
- CERT (Computer Emergency Response Team). Disponible en: <https://www.cert.org/>
- GnuPG Project. *GNU Privacy Guard*. Disponible en: <https://gnupg.org/>
- Informe sobre el ataque a Target (2014): Krebs on Security, "Target Hackers Broke in Via HVAC Company".
- Reporte del ataque a Colonial Pipeline (2021): U.S. Department of Justice.
- Caso Alstom: The Economist, "The Alstom affair".

Glosario

Glosario

- **Autenticación multifactor (MFA):** Método de autenticación que requiere dos o más factores independientes (algo que sabes, algo que tienes, algo que eres) para verificar la identidad de un usuario. Es clave para evitar accesos no autorizados incluso si la contraseña es robada.
- **Autenticidad:** Propiedad que garantiza que la identidad de un sujeto o el origen de un dato es genuino. Se logra con firmas digitales y certificados.
- **Cifrado asimétrico:** Sistema criptográfico que utiliza un par de claves (pública y privada). Lo que se cifra con una clave solo puede descifrarse con la otra.

- **CISSP**: Certified Information Systems Security Professional, certificación avanzada en seguridad de la información, enfocada en arquitectura y gestión.
- **CISM**: Certified Information Security Manager, certificación enfocada en la gobernanza y gestión de la seguridad.
- **Confidencialidad**: Principio de seguridad que asegura que la información no sea revelada a entidades no autorizadas.
- **Deepfake**: Técnica basada en inteligencia artificial para crear videos, audios o imágenes falsas pero muy realistas, utilizada en espionaje industrial para suplantar identidades de directivos.
- **Disponibilidad**: Principio que garantiza el acceso oportuno y fiable a la información por parte de los usuarios autorizados.
- **DLP (Data Loss Prevention)**: Sistemas que monitorean, detectan y bloquean la fuga de datos sensibles, ya sea a través de la red, dispositivos extraíbles o correo electrónico.
- **Espionaje industrial**: Obtención ilícita de información confidencial de una empresa por parte de competidores o agentes maliciosos, mediante técnicas como ingeniería social, malware o robo de secretos comerciales.
- **Firma digital**: Mecanismo criptográfico que permite autenticar el origen e integridad de un mensaje, proporcionando no repudio. No garantiza confidencialidad.
- **GDPR (Reglamento General de Protección de Datos)**: Normativa de la Unión Europea (vigente desde 2018) que regula el tratamiento de datos personales. Exige notificación de brechas en 72 horas y puede imponer multas de hasta 20 millones de euros o el 4% de la facturación global.
- **GnuPG**: GNU Privacy Guard, implementación libre del estándar OpenPGP para cifrado y firmas digitales.
- **Ingeniería social**: Técnica de manipulación psicológica para obtener información confidencial o accesos no autorizados, explotando el factor humano.
- **Integridad**: Principio que garantiza que la información no ha sido modificada de manera no autorizada.
- **ISO 27001**: Estándar internacional que especifica los requisitos para un Sistema de Gestión de Seguridad de la Información (SGSI). Versión actual: 2022.
- **ISO 27002**: Código de prácticas que proporciona una guía detallada de controles de seguridad (114 controles en su versión 2022). Complementario a ISO 27001.
- **No repudio**: Garantía de que una parte no puede negar haber realizado una acción (por ejemplo, haber enviado un mensaje). Se apoya en firmas digitales y registros de auditoría inmutables.
- **NIST SP 800-53**: Estándar del Instituto Nacional de Estándares y Tecnología de EE.UU. que ofrece un catálogo de controles de seguridad y privacidad, muy usado por agencias gubernamentales.

- **PCI DSS:** Payment Card Industry Data Security Standard, estándar de seguridad obligatorio para entidades que procesan, almacenan o transmiten datos de tarjetas de pago. Versión 4.0 vigente desde 2024.
- **Privacidad:** Derecho de las personas a controlar sus datos personales. Concepto legal y ético respaldado por confidencialidad e integridad.
- **SGSI:** Sistema de Gestión de Seguridad de la Información, marco de trabajo para gestionar la seguridad mediante políticas, procedimientos y controles, normalmente basado en ISO 27001.
- **Spear phishing:** Variante del phishing dirigida a una persona u organización específica, con mensajes altamente personalizados (a menudo generados con inteligencia artificial).
- **Zero Trust:** Modelo de seguridad basado en el principio de "Nunca confiar, siempre verificar". Exige autenticación y autorización continuas para cada acceso, incluso dentro de la red interna, y promueve la microsegmentación y el mínimo privilegio.